Phishing Email Analysis
This playbook provides step-by-step guidelines for SOC Level 1 analysts to investigate suspected phishing emails reported by end users or detected by security tools. Phishing emails aim to trick recipients into revealing sensitive information, downloading malware, or visiting malicious websites. Timely and accurate triage is essential to determine the threat level, contain any risk, and escalate as needed.

Step 1

Assign Alert
Assign received alert to yourself for investigation process.

Step 2

Alert Triaging Process
Familiarize yourself with the fields included in the alert. Review the phishing alert from your email security gateway (SEG), SIEM, or user report. Note available fields such as sender, subject, recipient, message ID, and delivery time.

Identify the time at which the email was received. Review the timestamp field or header to determine when the message was delivered to the recipient's inbox. This helps in scoping related activity.

Identify the specific asset associated with the alert. Determine which user or mailbox received the email. Note whether the user is a standard employee, VIP, or part of a sensitive business unit.

Identify the user associated with the activity. Look up the recipient in internal directory tools to determine their department, title, and whether they are active or privileged. Review the "To" or "Recipient" field.

Determine the malicious element in the email. Check whether the threat is a suspicious link, attachment, spoofed sender, or impersonation attempt.

Step 3

Analyze Email Artifacts
Follow steps 3.1–3.2 to detect potential anomalies and accurately classify the activity.

Step 3.1

Check Sender Reputation
Look up the sender’s domain/IP in the TryDetectThis app for threat intel.
Search historical mail logs to check if the sender has contacted other users.

Step 3.2

Review Attachments
Upload the attachment to TryDetectThis to assess for malicious indicators.
If no threats are found, manually review the file’s contents for suspicious behavior.

Step 4

Investigate Related Alerts
Identify other recipients who received the same email.
Check for process starts or detections related to the attachment or domain.
Search proxy and DNS logs for access to email-linked URLs.
Look for lateral movement via unusual logons or internal connections.

Step 5

Case Reporting
Classify the alert as True Positive or False Positive based on the results of your investigation.
Describe your analysis in the Case Report as specified in the "Alert Reporting" documentation section.
Submit and close alert.